

Análisis de Riesgos de Arquitectura Empresarial

Sistema de Gestión de Embargos y Desembargos — CF-JUR-PRO-002

Financiera Juriscoop S.A. Compañía de Financiamiento

Clasificación: Confidencial — Uso Interno

Versión: 1.0

Fecha: Mayo 2026

Marco de referencia: TOGAF 9.2 · ISO/IEC 27001:2022 · STRIDE · ArchiMate 3.1 · BPMN 2.0

1. Introducción Ejecutiva

1.1 El Análisis de Riesgos como Instrumento Estratégico de la Arquitectura Empresarial

En el contexto de la Arquitectura Empresarial (AE), el análisis de riesgos trasciende la función defensiva que se le atribuye en disciplinas puramente operativas o de ciberseguridad. Desde la perspectiva de TOGAF y el ADM (*Architecture Development Method*), el análisis de riesgos constituye un habilitador estratégico que permite alinear la evolución tecnológica con los objetivos corporativos, anticipar fricciones organizacionales antes de que se materialicen como pérdidas, y fundamentar decisiones de inversión arquitectónica con base en evidencia estructurada.

Identificar un riesgo en la capa de datos no es un ejercicio técnico aislado: es revelar que la organización toma decisiones de negocio sobre información potencialmente inconsistente. Identificar un riesgo de proceso no es simplemente señalar ineficiencia: es constatar que la continuidad operativa depende del conocimiento tácito de personas que pueden ausentarse, rotar o cometer errores bajo presión. En ese sentido, el análisis de riesgos de AE se convierte en el mecanismo que conecta la fragilidad operacional con sus consecuencias regulatorias, financieras y reputacionales.

1.2 Contexto Financiero y Regulatorio

Financiera Juriscoop S.A. Compañía de Financiamiento opera en un segmento del mercado financiero colombiano sujeto a supervisión directa de la **Superintendencia Financiera de Colombia (SFC)**, cuyas Circulares Externas y pronunciamientos sobre inembargabilidad definen umbrales operativos de obligatorio cumplimiento. Adicionalmente, el proceso de embargos y desembargos se articula con el sistema judicial a través del **Código General del Proceso (CGP)**, específicamente los artículos 593 y 594, que establecen un plazo máximo de **tres (3) días hábiles** para dar respuesta a una orden judicial de embargo.

Este marco regulatorio convierte al proceso CF-JUR-PRO-002 en un proceso de cumplimiento legal no negociable. El incumplimiento del SLA no genera únicamente una consecuencia operativa interna; genera exposición directa a sanciones administrativas por parte de la SFC, contingencias jurídicas por desacato a órdenes judiciales y, en escenarios extremos, riesgo reputacional sistémico que puede erosionar la confianza del regulador en la gestión institucional de la entidad.

Simultáneamente, la naturaleza del proceso involucra el tratamiento masivo de **datos personales y financieros** de ciudadanos bajo medidas judiciales, lo que activa las obligaciones derivadas de la **Ley 1581 de 2012 (Habeas Data)** y el **Decreto 1377 de 2013**. Esto implica que cada oficio procesado incorrectamente no solo representa un error operacional, sino una potencial vulneración de derechos fundamentales de protección de datos personales.

1.3 Criticidad del Proceso y Escala Operacional

El proceso CF-JUR-PRO-002 procesa aproximadamente **400 oficios judiciales diarios**, lo que representa una carga operacional significativa para una entidad del tamaño de Juriscoop. Bajo la arquitectura AS-IS, cada uno de estos oficios transita por un flujo de trabajo fragmentado que involucra manualmente a la Coordinación de Oficina, el Área de Operaciones, la Dirección Jurídica y, en ciertos casos, Tesorería; todo ello articulado a través de correos electrónicos, consultas individuales en BankVisión y registros en un archivo Excel denominado "Base Embargos".

La combinación de alto volumen, dependencia humana y ausencia de automatización configura un escenario donde el error no es una posibilidad remota, sino una consecuencia estadísticamente predecible. Con un flujo de 400 documentos diarios y múltiples puntos de intervención manual, incluso una tasa de error del 1% produce 4 casos problemáticos por día, 80 al mes y casi 1.000 al año, cada uno con potencial sancionatorio y con impacto directo en la experiencia y los derechos del cliente afectado.

1.4 Impacto Organizacional

La materialización de los riesgos identificados en este análisis puede impactar a Juriscoop en cuatro dimensiones simultáneas: **financiera** (multas regulatorias, contingencias judiciales, costos de reproceso), **operacional** (interrupción del flujo de trabajo, dependencia de personas clave, cuellos de botella), **reputacional** (deterioro de la relación con el regulador y con los clientes) y **estratégica** (imposibilidad de escalar el proceso ante el crecimiento del volumen de oficios sin una base tecnológica sólida).

El MVP de automatización propuesto no es, por tanto, un proyecto de modernización tecnológica discrecional. Es una respuesta arquitectónica a una vulnerabilidad operacional estructural con exposición regulatoria activa.

2. Relación Arquitectura AS-IS vs. TO-BE: Análisis Crítico

2.1 Por qué la Arquitectura Actual Genera Riesgos

La arquitectura AS-IS del proceso CF-JUR-PRO-002 presenta una disociación estructural entre sus componentes operacionales y tecnológicos. BankVisión, el core bancario, concentra la información transaccional de clientes y productos, pero está completamente desconectado del flujo de gestión documental de los oficios

judiciales. Esta brecha de interoperabilidad obliga a que la integración entre la orden judicial y la respuesta financiera se realice a través del criterio y la intervención manual del Auxiliar de Operaciones, quien debe consultar el sistema individualmente para cada oficio.

Esta arquitectura genera riesgos en al menos cuatro dimensiones estructurales:

Primero, concentración de conocimiento en personas. El cálculo de inembargabilidad requiere que el Analista Jurídico interprete y aplique las circulares de la SFC de manera manual. No existe un motor de reglas que garantice uniformidad en la aplicación del criterio normativo. Cuando distintos analistas aplican distintas interpretaciones, o cuando el analista comete un error aritmético, la organización no tiene ningún mecanismo sistémico de detección preventiva.

Segundo, ausencia de trazabilidad transaccional. El registro de la gestión de cada oficio reside en un archivo Excel ("Base Embargos") que no tiene control de versiones, no registra quién modificó qué campo ni cuándo, y no genera un log de auditoría verificable. En términos de gobierno de datos, esto equivale a operar sin bitácora: la organización no puede demostrar ante un ente regulador, de manera confiable e irrefutable, cuándo recibió un oficio, qué acciones tomó y en qué momento las completó.

Tercero, ausencia de alertamiento preventivo. El SLA legal de 3 días hábiles se gestiona mediante el seguimiento manual del Auxiliar de Operaciones. No existe ningún mecanismo automatizado que genere alertas cuando un caso está próximo a vencer. El cumplimiento del plazo depende de la memoria y la disciplina del operador, factores inherentemente frágiles en un proceso de alta carga como 400 oficios diarios.

Cuarto, exposición de datos sensibles por canales no seguros. La comunicación entre áreas se realiza a través del correo corporativo, incluyendo datos de identificación de clientes, saldos de cuentas y detalles de medidas judiciales. Este mecanismo no garantiza cifrado extremo a extremo, no controla el acceso posterior al mensaje una vez entregado, y no produce un registro de auditoría centralizado.

2.2 Cómo el TO-BE Reduce Vulnerabilidades

La arquitectura TO-BE propuesta materializa un cambio de paradigma: pasar de un modelo operacional basado en **intervención humana sobre datos dispersos** a un modelo basado en **orquestración sistémica con supervisión humana focalizada**. Este cambio no elimina la participación humana, sino que la reenfoca hacia las decisiones que realmente requieren juicio profesional (validación jurídica, casos excepcionales) y libera al personal operativo de tareas repetitivas de consulta y registro.

Los componentes del MVP abordan las vulnerabilidades estructurales identificadas de la siguiente manera: el **Motor de Inembargabilidad** elimina la variabilidad del criterio humano al parametrizar las reglas normativas de la SFC en lógica algorítmica verificable. La **Base de Datos Transaccional** sustituye el Excel por un repositorio con auditoría completa, integridad referencial y trazabilidad de eventos. La **integración con BankVisión** a través de middleware elimina la consulta manual individual y habilita validaciones masivas y automatizadas. El **Notificador SLA** elimina la dependencia de la memoria del operador, generando alertas automáticas antes del vencimiento del plazo legal.

2.3 Relación con Transformación Digital y Resiliencia Operacional

La propuesta TO-BE no debe entenderse únicamente como la digitización de un proceso manual. Desde la perspectiva de la transformación digital, representa la transición de un modelo operacional de **resiliencia frágil** (donde la continuidad depende de personas, archivos locales y comunicaciones informales) hacia un modelo de **resiliencia estructural** (donde la continuidad está garantizada por sistemas redundantes, procesos automatizados y datos persistentes en repositorios controlados).

Esta transición habilita capacidades que la arquitectura AS-IS hace imposibles: la posibilidad de escalar el volumen de oficios sin escalar proporcionalmente el equipo operativo, la capacidad de generar reportes de cumplimiento regulatorio de manera automatizada, y la base tecnológica necesaria para integraciones futuras con sistemas judiciales o con el Banco Agrario.

3. Identificación de Riesgos por Dominio

3.1 Riesgos de Negocio

3.1.1 Dependencia de Personas y Conocimiento Tácito

El proceso CF-JUR-PRO-002 opera sobre una base de conocimiento altamente tácito. El Analista Jurídico posee el entendimiento práctico de cómo aplicar las circulares de inembargabilidad de la SFC en casos concretos; el Auxiliar de Operaciones conoce los atajos y convenciones no documentadas de la Base Embargos en Excel; el Coordinador de Oficina maneja el protocolo informal de comunicación con el Banco Agrario. Este conocimiento no está sistematizado, no está documentado con suficiencia y no es transferible de manera eficiente.

El riesgo de negocio resultante es doble: en el corto plazo, la ausencia o indisponibilidad de cualquiera de estas personas (por enfermedad, renuncia, vacaciones o licencia) genera una reducción inmediata de la capacidad operativa del proceso, con el consecuente riesgo de incumplimiento del SLA legal. En el mediano plazo, la dependencia de conocimiento tácito impide la estandarización, dificulta el entrenamiento de nuevos colaboradores y hace que la calidad del servicio sea función de las personas y no de los procesos.

3.1.2 Impacto Financiero por Incumplimiento Regulatorio

La SFC tiene atribuciones sancionatorias explícitas sobre las entidades financieras vigiladas. El incumplimiento reiterado del SLA de 3 días hábiles establecido en el CGP puede resultar en multas administrativas, requerimientos formales y, en casos graves, en sanciones institucionales que trascienden el proceso específico. Adicionalmente, el error en el cálculo de inembargabilidad puede generar retenciones indebidas sobre mínimos legales protegidos, lo que expone a la entidad a demandas civiles por parte de los clientes afectados y a pronunciamientos sancionatorios del regulador.

3.1.3 Continuidad Operativa en Escenarios de Crisis

El proceso no cuenta con un plan de continuidad específico que defina los procedimientos alternativos en caso de indisponibilidad de BankVisión, falla del servidor donde reside el archivo Excel, o ausencia simultánea del personal clave. En un escenario de incidente mayor (p. ej., falla del core bancario durante un día

hábil completo), la entidad no tiene un protocolo sistematizado para gestionar los oficios que continúan llegando, lo que genera una acumulación de casos pendientes que puede comprometer el SLA legal en cadena.

3.1.4 Experiencia del Cliente y Riesgo Reputacional

Los clientes objeto de medidas de embargo son, por definición, personas en situación de vulnerabilidad financiera. Un error en el procesamiento de su caso (retención indebida, monto incorrecto, desembargo tardío) tiene impacto directo en su bienestar económico y genera una experiencia de cliente profundamente negativa. En el sector financiero cooperativo, donde la confianza y la relación asociativa son pilares del modelo de negocio, la reiteración de errores operacionales puede traducirse en deterioro de la vinculación, quejas formales ante la SFC y daño reputacional de mediano plazo.

3.2 Riesgos de Procesos

3.2.1 Excel como Sistema de Registro Transaccional

La utilización de un archivo Excel como "Base Embargos" —el registro central del proceso— representa quizás la vulnerabilidad operacional más crítica del estado AS-IS. Excel no fue diseñado para funcionar como sistema de registro transaccional en procesos de alta carga: carece de control de concurrencia (múltiples usuarios pueden sobrescribir datos simultáneamente sin advertencia), no genera logs de auditoría sobre modificaciones, no tiene integridad referencial, no soporta esquemas de permisos granulares y su disponibilidad depende del servidor de archivos donde esté alojado, que puede no tener las garantías de disponibilidad de un sistema transaccional.

En el BPMN AS-IS, el Excel aparece como el repositorio central sobre el cual el Auxiliar de Operaciones registra cada oficio y realiza el seguimiento de los 3 días hábiles. Esto significa que cualquier corrupción, pérdida o modificación no autorizada del archivo impacta directamente la capacidad de la organización de conocer el estado de sus procesos activos y de responder ante el regulador sobre el cumplimiento del SLA.

3.2.2 Reprocesos y Cuellos de Botella Estructurales

El flujo modelado en el BPMN AS-IS revela al menos tres puntos de espera estructural que generan latencia en el proceso. Primero, la recepción del oficio en la Coordinación de Oficina, su digitalización y el envío al área de Captaciones mediante correo introducen una demora variable que depende de la disponibilidad y la carga de cada actor. Segundo, la consulta individual en BankVisión para cada oficio es un proceso secuencial que no escala: a 400 oficios diarios, el tiempo acumulado de consulta manual puede ocupar una fracción significativa de la jornada laboral del Auxiliar de Operaciones, dejando poco margen para el seguimiento de casos anteriores. Tercero, la revisión de inembargabilidad por parte del Analista Jurídico, que debe realizarse de manera manual para cada caso, crea un cuello de botella en el único actor autorizado para aprobar la respuesta oficial.

3.2.3 Falta de Trazabilidad y Ausencia de Evidencia Jurídica

En un proceso con implicaciones judiciales, la trazabilidad no es un elemento de conveniencia operativa: es un requisito legal. La organización debe poder demostrar, ante un juzgado o ante la SFC, exactamente cuándo recibió cada oficio, qué validaciones realizó, qué respuesta emitió y en qué momento la remitió. La arquitectura AS-IS no garantiza esta trazabilidad: el registro en Excel puede ser modificado sin dejar rastro, los correos pueden ser eliminados, y no existe una línea de tiempo verificable e inalterable para cada caso.

3.2.4 Dependencias Inter-áreas sin Mecanismo de Escalamiento

El proceso involucra al menos cinco áreas diferentes (Oficina, Operaciones, Jurídica, Captaciones y Tesorería), cuya coordinación se realiza principalmente a través del correo electrónico. No existe un mecanismo sistematizado de escalamiento cuando un área no responde en el tiempo esperado, ni un panel de control que permita a un supervisor identificar en tiempo real qué casos están en riesgo de vencer el SLA. La coordinación inter-áreas descansa en la comunicación informal y en la buena voluntad de los actores, lo que es funcionalmente insostenible a escala de 400 oficios diarios.

3.3 Riesgos de Datos

3.3.1 Inconsistencia e Integridad de la Información

La arquitectura AS-IS configura dos repositorios de verdad paralelos y desconectados: BankVisión (que contiene los datos transaccionales de clientes y productos) y la Base Embargos en Excel (que contiene el registro de la gestión de los oficios). La sincronización entre ambos repositorios depende de la intervención manual del Auxiliar de Operaciones, quien consulta BankVisión y transcribe la información relevante al Excel. Esta transcripción manual es la fuente de múltiples riesgos de integridad: errores tipográficos en números de documento, transposición de cifras en saldos, asociación incorrecta de productos a personas, y desactualización cuando BankVisión es modificado después de que el Excel ya fue actualizado.

El modelo lógico de datos AS-IS (ERD), que mapea las relaciones entre Cliente, ProductoAhorro, OficioMedida y DepósitoJudicial, tiene coherencia semántica, pero en la práctica esta coherencia no está garantizada por ningún mecanismo de integridad referencial: las relaciones existen conceptualmente, pero no están reforzadas por restricciones técnicas en la capa de datos.

3.3.2 Duplicidad y Proliferación de Fuentes de Verdad

La comunicación por correo electrónico como mecanismo de intercambio de información entre áreas genera copias no controladas de los datos de los oficios en los buzones de múltiples colaboradores. Un oficio enviado por correo a Captaciones, reenviado para confirmación y respondido con datos adicionales, produce al menos cuatro instancias del mismo documento con potencialmente información diferente. Esta proliferación de fuentes de verdad hace imposible determinar cuál versión es la canónica en caso de discrepancia.

3.3.3 Exposición de Datos Personales y Financieros (PII)

El proceso trata datos de identificación personal (nombres, números de documento), datos financieros (saldos de cuentas, montos embargados) y datos de carácter judicial (número de radicado, autoridad ordenadora), todos los cuales constituyen información sensible bajo la Ley 1581 de 2012. En el estado AS-IS, estos datos se transmiten por correo electrónico corporativo sin cifrado verificado de extremo a extremo, se almacenan en un archivo Excel sin controles de acceso por campo, y eventualmente residen en los archivos adjuntos de múltiples buzones sin una política de retención o eliminación segura.

Esta situación configura una vulnerabilidad estructural respecto a los principios de **finalidad, necesidad y seguridad** establecidos en la normativa de protección de datos: los datos se distribuyen más allá de lo estrictamente necesario para el proceso, sin las garantías técnicas de protección adecuadas.

3.3.4 Ausencia de Gobierno de Datos

No existe una política formal de gobierno de datos para el proceso CF-JUR-PRO-002. No hay definición de propietarios de datos (*data owners*), no hay criterios documentados de calidad de datos, no hay un proceso formal de validación de la información antes de ingresarla al registro, y no hay métricas de calidad que permitan detectar deterioro progresivo de la información registrada. Esta ausencia hace que la confiabilidad de la Base Embargos sea, en el mejor de los casos, una estimación optimista basada en la diligencia individual de los operadores.

3.4 Riesgos de Aplicaciones

3.4.1 Dependencia Crítica del Core BankVisión

BankVisión es el sistema nuclear del proceso: sin acceso a él, no es posible validar la existencia de productos financieros del cliente, consultar saldos ni confirmar estados de cuenta. En la arquitectura AS-IS, esta dependencia es absoluta y no tiene alternativa: si BankVisión no está disponible, el proceso de validación se detiene completamente. No existe ningún mecanismo de caché, de consulta diferida o de acceso alternativo que permita continuar parcialmente la operación durante una ventana de indisponibilidad.

Adicionalmente, BankVisión es un sistema on-premise con una arquitectura legacy que no expone APIs estándar para integración. Esto significa que la única forma de obtener datos del core es mediante la intervención manual de un operador con acceso a la interfaz del sistema, lo que impide cualquier forma de automatización directa sin una capa de middleware o RPA.

3.4.2 Ausencia de APIs e Integraciones Frágiles

La arquitectura de aplicaciones AS-IS carece completamente de integraciones programáticas entre sus componentes. La relación entre el oficio judicial (entrada), BankVisión (validación) y el Excel (registro) es un flujo mediado enteramente por personas. Esta arquitectura es fundamentalmente frágil: cada punto de mediación humana es un punto potencial de error, demora o pérdida de información.

La ausencia de APIs implica también que cualquier mejora futura del proceso requerirá desarrollos de integración desde cero, sin una base establecida de contratos de interfaz o documentación de las capacidades del core. Esto genera deuda técnica arquitectónica que se acumula con cada ciclo sin inversión en interoperabilidad.

3.4.3 Deuda Técnica y Escalabilidad

La combinación de un core bancario legacy sin APIs, un sistema de registro en Excel y comunicaciones por correo representa un nivel de deuda técnica que limita severamente la capacidad de la organización de escalar el proceso o de adoptar innovaciones tecnológicas. Si el volumen de oficios aumentara significativamente (por cambios regulatorios, expansión de la cartera o incremento en la litigiosidad), la arquitectura actual no tiene capacidad de absorber ese incremento sin añadir proporcionalmente más personal operativo.

3.5 Riesgos de Infraestructura

3.5.1 Punto Único de Falla (SPOF) en BankVisión

BankVisión opera como un sistema on-premise sin redundancia documentada en el contexto del proceso analizado. Su indisponibilidad —ya sea por mantenimiento planificado, falla de hardware, actualización de software o incidente de seguridad— genera un SPOF que paraliza completamente la capacidad de la organización de responder a los oficios judiciales activos. En términos de continuidad, esto significa que un incidente en el core puede llevar al incumplimiento masivo del SLA legal de 3 días, con las consecuencias regulatorias ya descritas.

3.5.2 Fragilidad del Repositorio Excel

El archivo Excel de la Base Embargos, independientemente de dónde esté alojado (servidor de archivos compartido, unidad local, nube corporativa), no cuenta con las garantías de disponibilidad, integridad y recuperabilidad que caracterizan a un sistema transaccional robusto. No hay evidencia de backups diferenciados para este archivo con RPO (*Recovery Point Objective*) y RTO (*Recovery Time Objective*) definidos. Una corrupción del archivo, una eliminación accidental o una falla del servidor donde reside puede resultar en la pérdida permanente del historial de gestión de todos los casos activos.

3.5.3 Ausencia de Monitoreo y Observabilidad

La arquitectura AS-IS no tiene ningún mecanismo de monitoreo activo del estado del proceso: no hay dashboards de indicadores operacionales, no hay alertas automáticas por anomalías, no hay registro centralizado de eventos que permita a los supervisores conocer en tiempo real cuántos casos están activos, cuáles están en riesgo de vencer el SLA y cuáles han sido completados. Esta ausencia de observabilidad hace que la gestión del proceso sea reactiva por naturaleza: los problemas se detectan cuando ya han ocurrido, no cuando están gestándose.

3.6 Riesgos de Seguridad — Análisis STRIDE

La clasificación del sistema como **CRÍTICO** en términos de seguridad de la información se sustenta en tres factores concurrentes: el procesamiento masivo de PII financiera y judicial, la naturaleza regulatoria del proceso (con implicaciones legales directas sobre individuos), y la integración con el core bancario de la entidad. El siguiente análisis aplica el modelo STRIDE para identificar sistemáticamente las amenazas relevantes.

S — Spoofing (Suplantación de Identidad)

Amenaza: En el estado AS-IS, la autenticación del origen de un oficio judicial se basa en la recepción del documento por correo corporativo y la revisión visual por parte del coordinador de oficina. No existe un mecanismo sistematizado de verificación de autenticidad del oficio que valide criptográficamente su origen. Un actor malicioso podría fabricar un oficio judicial falso con formato convincente y remitirlo por correo, potencialmente logrando que la entidad embargue fondos de un cliente sin una orden judicial real.

Impacto: Retención indebida de fondos, responsabilidad penal y civil para la entidad, violación de derechos del cliente afectado.

Probabilidad: Media. Requiere conocimiento del proceso y capacidad para falsificar documentos judiciales, pero el canal de entrada (correo electrónico) es inherentemente vulnerable.

Arquitectura afectada: Procesos → Aplicaciones → Seguridad.

Mitigación propuesta (MVP): Implementar verificación de autenticidad mediante SPF/DKIM/DMARC para validar el dominio de origen del correo. Incluir en el flujo de trabajo un paso de "callback" telefónico a los juzgados para confirmar radicados de oficios de alto valor. En el TO-BE, la captura estructurada debe incluir validación del número de radicado contra registros verificables. Implementar MFA para todos los usuarios con acceso al sistema MVP.

T — Tampering (Manipulación de Datos)

Amenaza: La Base Embargos en Excel es editable por cualquier usuario con acceso al archivo, sin dejar rastro de las modificaciones. Un empleado malicioso o descuidado puede alterar montos, fechas, estados o cualquier campo del registro sin que el sistema detecte o registre el cambio. Asimismo, los datos en tránsito entre BankVisión y el registro Excel (transcripción manual) pueden ser alterados deliberada o accidentalmente durante la transcripción.

Impacto: Modificación fraudulenta de montos embargados, alteración de estados de cumplimiento para ocultar incumplimientos del SLA, falsificación de evidencia de gestión ante requerimientos regulatorios.

Probabilidad: Alta. No existen controles técnicos que prevengan la modificación del Excel por un insider.

Arquitectura afectada: Datos → Aplicaciones → Seguridad.

Mitigación propuesta (MVP): Sustituir el Excel por una base de datos transaccional con control de integridad y logs de auditoría inmutables (*append-only*). Implementar firma electrónica sobre los registros de gestión para garantizar su inalterabilidad. En el TO-BE, todos los cambios de estado de un caso deben quedar registrados con timestamp, usuario y valor anterior/posterior, en un log que no pueda ser modificado por ningún usuario operativo. Aplicar cifrado TLS 1.2+ sobre todos los canales de comunicación entre el MVP y BankVisión.

R — Repudiation (Repudio)

Amenaza: En la arquitectura AS-IS, la organización carece de evidencia digital irrefutable que acredite las acciones tomadas sobre cada oficio. Si un juzgado alega que la entidad no respondió en el plazo legal, o si un cliente alega que sus fondos fueron retenidos incorrectamente, la entidad no puede demostrar con certeza y evidencia técnicamente verificable qué hizo, quién lo hizo y cuándo. El correo electrónico puede ser eliminado, el Excel puede ser modificado y no existe un log centralizado e inalterable de las acciones realizadas.

Impacto: Imposibilidad de defensa ante requerimientos judiciales o regulatorios, exposición a sanciones por incumplimientos que sí fueron atendidos pero no pueden ser demostrados.

Probabilidad: Alta en el estado AS-IS. La ausencia de trazabilidad es una característica estructural de la arquitectura actual.

Arquitectura afectada: Procesos → Datos → Gobierno TI.

Mitigación propuesta (MVP): Implementar un sistema de logs inmutables con firma electrónica y timestamping certificado que registre cada evento del ciclo de vida del oficio. El MVP debe generar automáticamente un "expediente digital" de cada caso, con todos los eventos ordenados cronológicamente y protegidos contra modificación posterior. Este expediente constituirá la evidencia de cumplimiento ante cualquier requerimiento externo.

I — Information Disclosure (Divulgación de Información)

Amenaza: Los datos financieros y personales de los clientes objeto de embargo fluyen por canales no cifrados de extremo a extremo (correo corporativo), se almacenan en un archivo Excel sin controles de acceso por campo, y residen en buzones de correo de múltiples colaboradores sin una política de retención. Cualquier brecha en el servidor de correo, acceso no autorizado a un buzón comprometido o pérdida de un dispositivo con el archivo Excel puede resultar en la exposición masiva de datos sensibles.

Impacto: Violación de la Ley 1581 de 2012, sanción por parte de la SFC y la Superintendencia de Industria y Comercio (SIC), daño reputacional, y potencial uso de la información expuesta para fraudes dirigidos a los clientes afectados.

Probabilidad: Alta. Los controles actuales son insuficientes para la clasificación de criticidad del proceso.

Arquitectura afectada: Datos → Aplicaciones → Seguridad.

Mitigación propuesta (MVP): Implementar cifrado TLS 1.2+ en todos los canales de comunicación. Aplicar enmascaramiento de datos sensibles (salos, DNI) en los logs de aplicación. Implementar RBAC (*Role-Based Access Control*) con principio de *least privilege*: cada usuario accede únicamente a los datos necesarios para su función específica. Aplicar cifrado en reposo sobre la base de datos transaccional del MVP.

D — Denial of Service (Denegación de Servicio)

Amenaza: La dependencia absoluta de BankVisión como fuente de verdad transaccional significa que una ventana de indisponibilidad del core bancario —ya sea por ataque, falla técnica o mantenimiento no planificado— puede paralizar el proceso de validación de embargos durante horas o días. Con un SLA legal de 3 días hábiles, incluso una indisponibilidad de 24 horas puede representar el vencimiento del plazo para los casos recibidos el día anterior. Adicionalmente, un volumen inusualmente alto de oficios (p. ej., por una campaña de cobros masivos de una entidad judicial) podría saturar la capacidad operativa del equipo bajo la arquitectura manual actual.

Impacto: Incumplimiento masivo del SLA legal, sanciones regulatorias, acumulación de casos pendientes que se vuelve inmanejable.

Probabilidad: Media para indisponibilidad técnica; Alta para saturación operacional en picos de demanda.

Arquitectura afectada: Infraestructura → Aplicaciones → Procesos.

Mitigación propuesta (MVP): Diseñar el middleware de integración con BankVisión con capacidad de operación en modo degradado: en caso de indisponibilidad del core, el MVP debe poder recibir y registrar los oficios en cola, alertar al equipo operativo y reanudar la validación automáticamente cuando el core recupere disponibilidad. Implementar alertas de monitoreo sobre la disponibilidad de BankVisión integradas con el sistema de gestión de SLA.

E — Elevation of Privilege (Escalada de Privilegios)

Amenaza: En la arquitectura AS-IS, los controles de acceso a BankVisión y al Excel están basados en credenciales genéricas o perfiles de acceso amplios que no reflejan el principio de mínimo privilegio. Un Auxiliar de Operaciones con acceso amplio a BankVisión podría, teóricamente, ejecutar operaciones de bloqueo o desbloqueo sin la aprobación del Analista Jurídico o el área de Captaciones. La ausencia de un flujo de aprobación sistematizado con controles de segregación de funciones crea la posibilidad de que roles operativos ejecuten acciones que deberían requerir aprobación de nivel superior.

Impacto: Ejecución no autorizada de bloqueos o desbloqueos de cuentas, potencialmente con motivación fraudulenta o negligente; exposición ante auditorías regulatorias por insuficiencia de controles de segregación de funciones.

Probabilidad: Media. Depende de la configuración actual de roles en BankVisión y de los controles administrativos implementados.

Arquitectura afectada: Seguridad → Aplicaciones → Gobierno TI.

Mitigación propuesta (MVP): Implementar RBAC estricto con definición de roles diferenciados para Captura, Validación, Aprobación y Ejecución. Cada transición de estado del oficio (p. ej., de "pendiente validación" a "aprobado") debe requerir la intervención explícita del rol autorizado en el MVP, generando un registro inmutable. Implementar segregación de funciones que impida que un mismo usuario pueda registrar y aprobar el mismo caso. Aplicar el principio de Zero Trust: ningún usuario tiene acceso implícito; todo acceso debe ser explícitamente autorizado y verificado en cada sesión.

3.7 Riesgos de Gobierno TI

3.7.1 Ausencia de Estándares Arquitectónicos Documentados

El proceso CF-JUR-PRO-002 opera sin una arquitectura tecnológica formalmente documentada que defina los componentes del sistema, las responsabilidades de cada uno, los flujos de integración y las decisiones técnicas tomadas. Esto significa que el conocimiento sobre cómo funciona tecnológicamente el proceso reside en las personas que lo operan, no en documentación institucional. Cuando estas personas rotan, ese conocimiento se pierde y la organización debe reconstruirlo mediante observación empírica, con el costo y el riesgo que esto implica.

3.7.2 Ausencia de Gobierno de Cambios

No existe un proceso formal de gestión de cambios (*change management*) aplicable al proceso CF-JUR-PRO-002. Modificaciones en la configuración de BankVisión, cambios en la estructura del Excel, actualizaciones en los criterios de inembargabilidad por nuevas circulares de la SFC, o cambios en los procedimientos del equipo pueden implementarse sin un proceso de evaluación de impacto, sin comunicación formal a todos los actores involucrados y sin un mecanismo de rollback en caso de problemas. Este vacío de gobierno es particularmente crítico cuando los cambios regulatorios exigen ajustes rápidos en las reglas de negocio: sin un proceso formal, la velocidad de adaptación depende de la iniciativa individual, no de un mecanismo institucional controlado.

3.7.3 Falta de Métricas y KPIs de Gobierno

La organización no tiene un sistema de medición formal del desempeño del proceso CF-JUR-PRO-002 con KPIs definidos, umbrales de alerta y ciclos de revisión periódica. Si bien el documento de proyecto propone metas de cumplimiento (100% de respuesta en SLA, 100% de precisión en inembargabilidad, 99.5% de disponibilidad), actualmente no existe el sistema de medición que permita verificar el cumplimiento de estas metas ni detectar su deterioro progresivo.

3.7.4 Documentación Insuficiente y Dependencia del Procedimiento Interno

El manual interno CF-JUR-PRO-002 (Versión 3) constituye la base documental del proceso, pero un procedimiento escrito no es equivalente a una arquitectura documentada. El manual describe qué hacen las personas, pero no cómo están configurados los sistemas, qué datos se almacenan y dónde, qué controles técnicos existen o cuáles son las dependencias críticas. Esta brecha entre el procedimiento operativo y la documentación arquitectónica es un riesgo de gobierno que se materializa típicamente durante auditorías, incidentes o procesos de transformación.

4. Matriz de Riesgos Empresarial

#	Riesgo	Causa Raíz	Impacto	Probabilidad	Criticidad	Dominio	Arquitectura Afectada	Mitigación Propuesta	Pri
---	--------	------------	---------	--------------	------------	---------	-----------------------	----------------------	-----

#	Riesgo	Causa Raíz	Impacto	Probabilidad	Criticidad	Dominio	Arquitectura Afectada	Mitigación Propuesta	Pri
R-01	Incumplimiento del SLA legal de 3 días hábiles	Seguimiento manual sin alertas automáticas; dependencia del auxiliar de operaciones	Sanciones SFC, desacato judicial, contingencias legales	Alta	Crítico	Procesos / Negocio	Procesos → Aplicaciones	Notificador SLA automático con alertas escalonadas a 72h, 48h y 24h antes del vencimiento	Inn
R-02	Error en cálculo de inembargabilidad	Cálculo manual por analista jurídico sin validación algorítmica	Retención indebida sobre mínimos protegidos; sanciones regulatorias; demandas civiles	Alta	Crítico	Negocio / Procesos / Datos	Procesos → Aplicaciones → Datos	Motor de reglas paramétrico basado en circulares SFC con cobertura del 100% de escenarios	Inn
R-03	Pérdida o corrupción de la Base Embargos (Excel)	Ausencia de sistema transaccional robusto; repositorio frágil sin integridad de datos	Pérdida del historial completo de casos activos; incapacidad de responder ante regulador	Media	Crítico	Datos / Infraestructura	Datos → Infraestructura	Migración a base de datos relacional con backups automáticos, RPO < 1 hora y RTO < 4 horas	Inn
R-04	Falsificación de oficios judiciales (Spoofing)	Ausencia de verificación criptográfica del origen de los documentos	Embargo fraudulento de fondos sin orden judicial válida; responsabilidad penal	Baja	Alto	Seguridad / Negocio	Seguridad → Procesos	Implementación de SPF/DKIM/DMARC; verificación por callback a juzgados; validación de radicados	Urg
R-05	Manipulación de registros en Excel (Tampering)	Sin control de versiones ni logs de auditoría sobre el archivo Excel	Alteración fraudulenta de montos, fechas y estados; falsificación de evidencia de cumplimiento	Alta	Crítico	Seguridad / Datos	Datos → Seguridad	Logs inmutables con firma electrónica; base de datos append-only; auditoría centralizada	Inn
R-06	Repudio de acciones ante entes reguladores	Ausencia de evidencia digital irrefutable sobre el ciclo de vida de cada caso	Incapacidad de defensa ante requerimientos judiciales o de la SFC	Alta	Crítico	Gobierno TI / Seguridad	Datos → Gobierno	Expediente digital inmutable por caso; timestamping certificado; SIEM con retención de logs	Inn
R-07	Exposición de PII financiera y judicial por canales no seguros	Transmisión de datos sensibles por correo no cifrado E2E	Violación Ley 1581; sanción SIC; fraude a clientes con datos expuestos	Alta	Crítico	Seguridad / Datos	Seguridad → Datos	Cifrado TLS 1.2+; cifrado en reposo; enmascaramiento de PII en logs; canal seguro para comunicaciones inter-áreas	Inn
R-08	Indisponibilidad de BankVisión (SPOF)	Arquitectura on-premise sin redundancia; dependencia absoluta del core	Paralización total del proceso de validación; incumplimiento masivo del SLA	Media	Crítico	Infraestructura / Procesos	Infraestructura → Aplicaciones	Modo degradado en MVP con cola de procesamiento; monitoreo activo de disponibilidad del core; procedimiento de contingencia documentado	Urg

#	Riesgo	Causa Raíz	Impacto	Probabilidad	Criticidad	Dominio	Arquitectura Afectada	Mitigación Propuesta	Pri
R-09	Escalada de privilegios en BankVisión y Excel	Ausencia de RBAC estricto y segregación de funciones; accesos genéricos o amplios	Operaciones no autorizadas; bloqueos/desbloqueos sin aprobación jurídica	Media	Alto	Seguridad / Gobierno TI	Seguridad → Aplicaciones	RBAC con roles diferenciados; segregación de funciones sistematizada; principio de mínimo privilegio; Zero Trust	Urg
R-10	Dependencia de conocimiento tácito del equipo operativo	Ausencia de sistematización del proceso; conocimiento concentrado en personas	Reducción de capacidad operativa por ausentismo; errores de reemplazo; riesgo de continuidad	Alta	Alto	Negocio / Gobierno TI	Negocio → Procesos	Sistematización del proceso en el MVP; documentación arquitectónica formal; capacitación estructurada	Urg
R-11	Saturación operacional en picos de demanda	Proceso manual sin capacidad de escala automática; volumen de 400+ oficios diarios	Acumulación de backlog; incumplimiento del SLA para casos de cola de espera	Alta	Alto	Procesos / Infraestructura	Procesos → Aplicaciones	Automatización del cruce de saldos con BankVisión; procesamiento en lote; panel de control con indicadores de carga	Urg
R-12	Ausencia de gobierno de cambios regulatorios	Sin proceso formal de actualización de reglas ante nuevas circulares SFC	Aplicación de criterios desactualizados de inembargabilidad; errores sistemáticos en el proceso	Media	Alto	Gobierno TI / Cumplimiento	Gobierno → Aplicaciones	Motor de reglas parametrizable sin necesidad de desarrollo; proceso formal de change management para actualizaciones normativas	Est
R-13	Duplicidad y silos de información inter-áreas	Múltiples repositorios no integrados; correo como canal de datos	Decisiones tomadas sobre datos desactualizados o inconsistentes entre áreas	Alta	Alto	Datos / Procesos	Datos → Aplicaciones	Base de datos centralizada como única fuente de verdad; eliminación del correo como canal de datos entre áreas	Urg
R-14	Falta de observabilidad del proceso	Sin dashboards, métricas ni alertas en tiempo real	Detección tardía de problemas; gestión reactiva; incapacidad de mejora continua basada en datos	Alta	Medio	Gobierno TI / Infraestructura	Infraestructura → Gobierno	SIEM centralizado; dashboard operacional con KPIs en tiempo real; alertas automáticas por umbrales definidos	Est
R-15	Vendor lock-in y obsolescencia del core BankVisión	Arquitectura legacy sin APIs estándar; dependencia de proveedor único	Limitación para adoptar nuevas tecnologías; costos elevados de integración futura	Baja	Medio	Aplicaciones / Estrategia	Aplicaciones → Infraestructura	Diseño de capa de integración desacoplada (middleware/anti-corruption layer) que abstraiga la dependencia del core; documentación de la API interna	Est

#	Riesgo	Causa Raíz	Impacto	Probabilidad	Criticidad	Dominio	Arquitectura Afectada	Mitigación Propuesta	Pri
R-16	Incumplimiento de Ley 1581 por gestión de datos sin consentimiento documentado	Ausencia de gestión sistematizada de consentimientos y derechos ARCO	Sanción administrativa SIC; afectación reputacional; demandas individuales	Media	Alto	Cumplimiento / Datos	Datos → Negocio	Módulo de gestión de bases de datos personales; procedimiento documentado para atención de derechos ARCO; registro de tratamiento de datos	Urg
R-17	Denegación de servicio por volumen inusual de oficios	Ausencia de mecanismo de gestión de carga; proceso secuencial no paralelizable	Colapso operacional; incumplimiento masivo de SLA por incapacidad de absorber pico de demanda	Media	Alto	Infraestructura / Procesos	Infraestructura → Aplicaciones	Arquitectura de procesamiento en lote con capacidad de paralelización; alertas de saturación de capacidad; cola de prioridad por urgencia normativa	Urg

5. Gap Analysis Estratégico

5.1 Dimensión: Procesos

Capacidad	Estado AS-IS	Estado TO-BE (MVP)	Brecha	Riesgo Residual
Recepción y radicación de oficios	Manual, vía correo y revisión física por Coordinador de Oficina	Captura estructurada centralizada en la plataforma MVP con extracción de datos clave	Alta: requiere módulo de ingesta y digitalización	Oficios físicos no estandarizados aún requieren intervención humana
Validación de existencia de productos	Consulta individual y manual en BankVisión por Auxiliar de Operaciones	Consulta automática y masiva mediante integración API/RPA con BankVisión	Alta: requiere desarrollo de middleware	Dependencia de disponibilidad del core; modo degradado limitado
Cálculo de inembargabilidad	Cálculo mental/manual por Analista Jurídico según circulares SFC	Motor de reglas paramétrico con aplicación algorítmica de topes normativos	Alta: requiere parametrización completa de reglas normativas	Actualizaciones regulatorias requieren mantenimiento del motor
Seguimiento SLA 3 días hábiles	Seguimiento manual por Auxiliar de Operaciones; sin alertas automáticas	Sistema de alertas automáticas escalonadas antes del vencimiento del SLA	Media: requiere configuración del notificador y calendario laboral	Errores en configuración del calendario pueden generar alertas incorrectas
Generación de respuestas oficiales	Redacción manual de cada respuesta por Analista Jurídico	Pre-generación automática de respuestas basadas en plantillas; aprobación human-in-the-loop	Media: requiere diseño de plantillas y flujo de aprobación	La aprobación jurídica final sigue siendo humana (requerida por naturaleza del proceso)

5.2 Dimensión: Datos

Capacidad	Estado AS-IS	Estado TO-BE (MVP)	Brecha	Por qué es Riesgoso
Repositorio central del proceso	Excel "Base Embargos" sin integridad, versionamiento ni auditoría	Base de datos relacional transaccional con auditoría completa e integridad referencial	Crítica: migración y diseño de esquema de datos	El Excel no garantiza la integridad de los datos que sustentan el cumplimiento legal
Trazabilidad de eventos	Ninguna: modificaciones en Excel sin registro; correos eliminables	Log inmutable con timestamping y firma electrónica para cada evento del ciclo del oficio	Crítica: requiere diseño del modelo de auditoría	Sin trazabilidad, la entidad no puede demostrar cumplimiento ante el regulador
Calidad y consistencia de datos	Sin controles de validación; dependiente del criterio del operador	Validaciones automáticas al ingreso de datos; consistencia garantizada por restricciones de la BD	Alta: requiere definición de reglas de calidad	Datos de baja calidad en la BD del MVP pueden generar errores en el motor de reglas
Gobierno de datos	Sin propietarios definidos, sin métricas de calidad, sin política de retención	Modelo de gobierno básico con propietarios por entidad, política de retención y métricas de calidad	Media: requiere implementación de políticas de gobierno	El gobierno de datos es un proceso de maduración continua, no un estado final

5.3 Dimensión: Aplicaciones

Capacidad	Estado AS-IS	Estado TO-BE (MVP)	Brecha	Cómo el MVP lo mitiga
Integración con core bancario	Ninguna (manual)	Middleware de integración con BankVisión para consultas automáticas de saldos	Crítica	Elimina la consulta individual y el riesgo de error de transcripción
Motor de decisiones normativas	Ninguno (juicio humano)	Motor de reglas parametrizable basado en circulares SFC	Crítica	Garantiza uniformidad y auditabilidad del criterio de inembargabilidad
Gestión del ciclo de vida del oficio	Excel + correo	Plataforma centralizada con estados, transiciones y aprobaciones sistematizadas	Alta	Elimina los silos de información y habilita el seguimiento en tiempo real
Alertamiento y notificaciones	Ninguno	Notificador automático de vencimiento SLA con escalamiento por roles	Alta	Elimina la dependencia de la memoria del operador para el cumplimiento del plazo

5.4 Dimensión: Seguridad

Capacidad	Estado AS-IS	Estado TO-BE (MVP)	Brecha	Riesgo si no se cierra
Autenticación de usuarios	Sin MFA; credenciales básicas en BankVisión y correo corporativo	MFA obligatorio para todos los accesos al MVP y BankVisión	Crítica	Compromiso de credenciales permite acceso total al sistema sin barrera adicional
Control de acceso por roles	Sin RBAC sistematizado; accesos amplios o genéricos	RBAC estricto con roles diferenciados para cada función del proceso	Alta	Sin segregación de funciones, cualquier usuario puede ejecutar acciones no autorizadas
Cifrado de datos sensibles	Sin cifrado en tránsito verificado E2E; sin cifrado en reposo en Excel	TLS 1.2+ en tránsito; cifrado en reposo en BD; enmascaramiento en logs	Crítica	Exposición de PII financiera y judicial en canales y repositorios no protegidos
Auditoría y SIEM	Sin logs centralizados ni monitoreo de seguridad	SIEM con correlación de eventos; alertas por comportamientos anómalos	Alta	Sin detección proactiva, los incidentes de seguridad se identifican cuando ya causaron daño

5.5 Dimensión: Infraestructura y Gobierno

Capacidad	Estado AS-IS	Estado TO-BE (MVP)	Brecha	Riesgo Residual
Disponibilidad del proceso	Depende de BankVisión y del servidor del Excel; sin SLA definido	MVP con modo degradado y monitoreo activo; disponibilidad objetivo 99.5%	Alta	Dependencia del core bancario permanece como riesgo residual
Documentación arquitectónica	Manual de procedimiento operativo (CF-JUR-PRO-002 v3); sin documentación técnica de la arquitectura	Documentación arquitectónica completa: diagramas C4, ArchiMate, ADR (<i>Architecture Decision Records</i>)	Alta	La documentación requiere mantenimiento activo para reflejar la evolución del sistema
Gobierno de cambios	Sin proceso formal; cambios implementados de manera ad hoc	Proceso de change management documentado con evaluación de impacto regulatorio obligatoria	Media	La disciplina de gobierno requiere compromiso organizacional sostenido

6. Arquitectura de Mitigación TO-BE

6.1 Automatización como Reducción Sistemática del Error Humano

La automatización implementada en el MVP no es un fin en sí mismo: es el mecanismo mediante el cual la organización reduce la dependencia del juicio humano en tareas repetitivas, algorítmicas y de alta carga, redirigiendo la atención del equipo operativo hacia las decisiones que realmente requieren discernimiento profesional.

El **Motor de Inembargabilidad** parametriza las reglas normativas de la SFC en lógica algorítmica verificable, garantizando que el cálculo de los montos inembargables sea idéntico, correcto y auditable para los ~400 oficios diarios, independientemente de quién opere el sistema, de la carga de trabajo del momento o de la experiencia del analista. Esta automatización aborda directamente los riesgos R-02 (error en cálculo) y R-12 (desactualización por cambios normativos).

La **integración con BankVisión** mediante middleware elimina la consulta manual individual y el riesgo de error de transcripción asociado. En lugar de que el auxiliar consulte manualmente cada producto en el core y transcriba el saldo al Excel, el MVP consulta automáticamente los productos activos del cliente identificado en el oficio y obtiene los saldos en tiempo real, reduciendo el tiempo de validación y eliminando la variabilidad humana del proceso.

6.2 Trazabilidad como Fundamento del Cumplimiento Regulatorio

La **base de datos transaccional** del MVP es el componente arquitectónico de mayor impacto en la reducción del riesgo regulatorio. Al sustituir el Excel por un repositorio relacional con auditoría completa, la organización obtiene tres capacidades que son fundamentales para su relación con la SFC y el sistema judicial:

Evidencia de cumplimiento inalterable: Cada evento del ciclo de vida de un oficio (recepción, validación, aprobación, respuesta, archivo) queda registrado con timestamp, usuario responsable y datos del estado anterior y posterior. Este registro es inmutable: ningún usuario operativo puede modificarlo. Ante un requerimiento judicial o una auditoría regulatoria, la organización puede generar de manera automática el expediente digital completo de cualquier caso, con plena certeza sobre su integridad.

Métricas de cumplimiento en tiempo real: Los KPIs propuestos (tasa de respuesta en SLA, precisión de inembargabilidad, disponibilidad) dejan de ser aspiracionales para convertirse en métricas medibles en tiempo real. El panel de control operacional permite que los supervisores identifiquen inmediatamente qué casos están en riesgo de vencer el SLA y tomen acción antes de que se materialice el incumplimiento.

Gobierno del dato como activo estratégico: La definición de un esquema de datos normalizado, con propietarios de entidades, restricciones de integridad y políticas de retención, transforma los datos del proceso de un subproducto operacional (el Excel) en un activo estratégico gestionado: disponible para análisis, para reportes regulatorios automatizados y para la toma de decisiones basada en evidencia.

6.3 Seguridad por Diseño bajo Zero Trust

La arquitectura de seguridad del MVP está fundamentada en el principio de **Zero Trust**: ningún usuario, sistema o componente tiene acceso implícito a los recursos del proceso. Todo acceso debe ser explícitamente autorizado, verificado en cada sesión y registrado. Este enfoque contrasta con el modelo de confianza implícita de la arquitectura AS-IS, donde el acceso al Excel y a BankVisión se basa en credenciales básicas sin verificación adicional.

La implementación de **MFA** como requisito universal de autenticación elimina el principal vector de ataque de Spoofing: incluso si las credenciales de un usuario son comprometidas, el atacante no puede acceder al sistema sin el segundo factor de autenticación. Complementariamente, el **RBAC** con segregación de funciones garantiza que un usuario comprometido solo puede acceder a los datos y funciones de su rol específico, limitando el alcance del daño potencial.

El **SIEM** centraliza los logs de seguridad de todos los componentes del sistema y aplica reglas de correlación para detectar comportamientos anómalos: múltiples intentos de autenticación fallidos, accesos fuera del horario habitual, consultas masivas inusuales o modificaciones de estados sin la secuencia esperada de aprobaciones. Esta capacidad de detección proactiva convierte al equipo de seguridad de una postura reactiva (responder cuando ocurre el incidente) a una postura preventiva (detectar el incidente mientras ocurre o antes de que cause daño).

6.4 Resiliencia Operacional y Continuidad

El diseño de resiliencia del MVP contempla explícitamente el escenario de indisponibilidad parcial: cuando BankVisión no está disponible, el sistema debe ser capaz de continuar recibiendo y registrando oficios en cola, alertar automáticamente al equipo operativo, y reanudar el procesamiento cuando el core recupere disponibilidad. Este modo degradado garantiza que la interrupción de un componente no resulte en la interrupción total del proceso.

Esta capacidad de **operación en modo degradado**, complementada con backups automáticos de la base de datos con RPO menor a 1 hora, elimina el SPOF que caracteriza la arquitectura AS-IS y garantiza que la organización pueda continuar cumpliendo sus obligaciones regulatorias incluso en escenarios de incidente parcial.

6.5 Cumplimiento Normativo como Atributo de Calidad del Sistema

El MVP incorpora el cumplimiento regulatorio como un atributo de calidad sistémico, no como una verificación manual post-proceso. La parametrización del motor de reglas con los criterios de la SFC, la generación automática de alertas de SLA basadas en el calendario de días hábiles, y la producción automática de reportes de cumplimiento convierten al sistema en un habilitador del cumplimiento regulatorio, en lugar de un riesgo para él.

Este enfoque está alineado con los requerimientos de TOGAF (específicamente la Fase F del ADM, que cubre la planificación de la migración con foco en beneficios medibles) y con los controles de ISO/IEC 27001:2022, que exigen no solo la implementación de controles de seguridad sino su demostración documentada y medible.

7. Riesgos Residuales

Incluso con la implementación completa del MVP propuesto, ciertos riesgos permanecerán activos en la arquitectura y requerirán monitoreo continuo y planes de gestión específicos.

7.1 Dependencia del Core Bancario BankVisión

La integración del MVP con BankVisión, aunque elimina la consulta manual, no elimina la dependencia funcional del core bancario. Si BankVisión experimenta una indisponibilidad prolongada (superior a 24 horas), el modo degradado del MVP puede sostener la recepción de oficios pero no puede completar las validaciones de saldo. Este riesgo solo puede mitigarse estructuralmente mediante una estrategia de modernización del core a largo plazo que incluya la exposición de APIs estándar y la implementación de redundancia a nivel de infraestructura.

Recomendación futura: Diseñar e implementar una API Gateway sobre BankVisión que exponga capacidades de consulta de saldos y estados de producto de manera estándar, versionada y con SLA de disponibilidad definido. Esto reducirá el riesgo y habilitará integraciones futuras con mayor agilidad.

7.2 Indisponibilidad de Fuentes Judiciales Externas

El MVP asume que los oficios judiciales son recibidos a través de canales controlados (correo corporativo estructurado). Sin embargo, la Rama Judicial no tiene integración directa con el MVP (está fuera del alcance del MVP actual), lo que significa que los oficios enviados por canales no estándar, en formatos no estandarizados o a través de medios atípicos (p. ej., diligencias físicas) pueden no ser capturados automáticamente por el sistema.

Recomendación futura: Desarrollar en una fase posterior la integración directa con el sistema de notificaciones judiciales electrónicas, eliminando la dependencia de la recepción manual de oficios y reduciendo el tiempo de ingreso al proceso.

7.3 Errores en la Parametrización del Motor de Reglas

El Motor de Inembargabilidad elimina el error humano en la *aplicación* de las reglas, pero introduce un nuevo riesgo: el error en la *parametrización* de las reglas. Si los criterios normativos de la SFC son interpretados incorrectamente al ser codificados en el motor, el sistema aplicará de manera sistemática y masiva un criterio incorrecto, amplificando el error en lugar de prevenirlo. Este riesgo es especialmente relevante cuando la SFC emite nuevas circulares o actualiza los umbrales de inembargabilidad.

Recomendación futura: Implementar un proceso formal de validación jurídica de cada actualización del motor de reglas, con pruebas de regresión documentadas sobre casos históricos antes de cada despliegue en producción. Mantener un repositorio de casos de prueba que cubra todos los escenarios normativos conocidos.

7.4 Riesgo Humano en el Componente Human-in-the-Loop

El modelo Human-in-the-Loop del MVP delega la aprobación final de las respuestas a los oficios al Analista Jurídico. Este componente es deliberado y necesario: la naturaleza jurídica del proceso requiere validación humana calificada. Sin embargo, significa que el riesgo humano no es eliminado, sino concentrado en el punto de mayor criticidad. Un analista bajo presión, sin los recursos de consulta adecuados o con una interpretación jurídica equivocada, puede generar errores que el sistema ejecutará con plena trazabilidad pero no podrá prevenir.

Recomendación futura: Diseñar el interfaz del componente human-in-the-loop con apoyo de decisión contextual: mostrar al analista, junto con cada caso, el historial de casos similares, los criterios normativos aplicables y las alertas de riesgo identificadas por el sistema, para reducir la probabilidad de error en la etapa de aprobación.

7.5 Vendor Lock-in y Dependencia Cloud

Si el MVP es desplegado sobre infraestructura cloud (AWS, Azure, GCP), la organización adquiere una dependencia de la plataforma proveedora que puede generar costos crecientes, riesgos de discontinuación de servicios y dificultades para la migración futura. Este riesgo es inherente a cualquier arquitectura cloud y debe gestionarse desde el diseño inicial mediante el uso de estándares abiertos, contenedores, y arquitecturas portables.

Recomendación futura: Adoptar una estrategia de diseño cloud-agnostic desde el inicio del MVP: uso de contenedores (Docker/Kubernetes), evitar servicios propietarios sin alternativa estándar, y documentar las dependencias de plataforma para facilitar una eventual migración.

7.6 Madurez Organizacional en Gobierno de Datos

La implementación del MVP provee la plataforma tecnológica para el gobierno de datos, pero el gobierno de datos como capacidad organizacional requiere también cambios en cultura, procesos y roles que van más allá de la tecnología. La tentativa de seguir usando el Excel como respaldo "por si acaso", la resistencia al cambio en el equipo operativo o la falta de un *data owner* activo pueden erosionar la calidad de los datos en la nueva base de datos y replicar los problemas del AS-IS en el TO-BE.

Recomendación futura: Implementar un programa de gestión del cambio organizacional paralelo al despliegue del MVP, que incluya capacitación, definición formal de roles de datos, y métricas de adopción para garantizar que el equipo operativo abandone completamente los mecanismos manuales en favor del sistema.

8. Conclusiones Ejecutivas

8.1 La Arquitectura Empresarial como Habilitador Estratégico

El análisis desarrollado en este documento demuestra que la arquitectura actual del proceso CF-JUR-PRO-002 no es únicamente técnicamente deficiente: es estratégicamente vulnerable. La combinación de procesos manuales, datos fragmentados, ausencia de trazabilidad y dependencia de conocimiento tácito configura un escenario donde el cumplimiento regulatorio es consecuencia del esfuerzo individual de las personas, no de la robustez del sistema. Esta diferencia es fundamental: un cumplimiento basado en el esfuerzo individual es frágil, no escala y no puede ser demostrado con certeza ante un ente regulador.

La propuesta de MVP de automatización, analizada desde la perspectiva de la Arquitectura Empresarial con los marcos TOGAF, ISO/IEC 27001 y STRIDE, no es un proyecto de mejora tecnológica incremental. Es la transformación del proceso de embargos y desembargos de un modelo de **resiliencia frágil** a un modelo de **resiliencia estructural**: donde la continuidad operativa, la precisión normativa y la trazabilidad del cumplimiento son atributos del sistema, no consecuencias contingentes del desempeño individual.

8.2 Priorización Estratégica del Roadmap de Mitigación

Del análisis de la matriz de riesgos se desprende una priorización clara de las intervenciones arquitectónicas:

Las acciones de **prioridad inmediata** (R-01, R-02, R-03, R-05, R-06, R-07) abordan los riesgos que combinan alta probabilidad con criticidad máxima y exposición regulatoria directa. Estas intervenciones deben ser las primeras en implementarse en el MVP y su completitud debe ser condición de puesta en producción.

Las acciones de **prioridad urgente** (R-04, R-08, R-09, R-10, R-11, R-13, R-16, R-17) abordan vulnerabilidades de alto impacto cuya probabilidad o complejidad de mitigación es ligeramente menor, pero que deben ser completadas en las primeras semanas posteriores al despliegue del MVP.

Las acciones de **prioridad estratégica** (R-12, R-14, R-15) configuran la hoja de ruta de madurez arquitectónica a mediano plazo: gobierno de cambios regulatorios, observabilidad avanzada y desacoplamiento del core bancario son las capacidades que permitirán a Juriscoop escalar el sistema y mantener su ventaja de cumplimiento en el largo plazo.

8.3 El Valor Financiero de la Mitigación de Riesgos

Desde una perspectiva financiera, la inversión en el MVP debe evaluarse no solo en términos de ahorro operacional (reducción de horas-hombre en consultas manuales y reprocesos), sino en términos del **valor en riesgo** que mitiga. Las sanciones de la SFC por incumplimiento reiterado del SLA, las contingencias judiciales por retenciones indebidas y los costos de un eventual incidente de seguridad que exponga datos de clientes representan exposiciones financieras que superan con creces el costo de implementación del MVP. En este sentido, el análisis de riesgos de Arquitectura Empresarial tiene un retorno sobre inversión demostrable y cuantificable.

8.4 La Arquitectura Empresarial como Lenguaje Común de la Transformación

Quizás la contribución más valiosa de este análisis desde la perspectiva institucional es que establece un **lenguaje común** entre los dominios de negocio, tecnología, cumplimiento y seguridad. Los 17 riesgos identificados y los 5 dominios de brecha analizados no son problemas de IT: son problemas del negocio que tienen solución arquitectónica. Esta distinción es fundamental para lograr el compromiso directivo necesario para la implementación del MVP: cuando el área jurídica comprende que el riesgo de incumplimiento del SLA tiene una causa raíz tecnológica mitigable, y cuando el área de sistemas comprende que la implementación de RBAC tiene implicaciones jurídicas directas, la transformación se convierte en un proyecto institucional, no en un proyecto de una sola área.

La Arquitectura Empresarial, bien aplicada, no es el mapa del sistema de información de una organización. Es el mapa de cómo la organización crea valor, gestiona riesgos y toma decisiones. Este análisis demuestra que Financiera Juriscoop S.A. tiene en el proceso CF-JUR-PRO-002 no solo una oportunidad de modernización, sino una necesidad estratégica de transformación cuya postergación tiene un costo regulatorio, operacional y financiero creciente.

Referencias

- The Open Group. (2018). *The TOGAF® Standard, Version 9.2*. The Open Group.
- Financiera Juriscoop S.A. (2026). *Procedimiento: Embargo y Desembargo* (Código: CF-JUR-PRO-002, Versión 3). Documento interno de control operativo.
- Superintendencia Financiera de Colombia. *Carta Circular sobre montos de inembargabilidad y exención de juicio de sucesión*.
- Congreso de la República de Colombia. *Código General del Proceso* (Artículos 593 y 594).
- Congreso de la República de Colombia. *Ley 1581 de 2012 — Ley de Protección de Datos Personales (Habeas Data)*.
- ISO/IEC 27001:2022. *Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements*. International Organization for Standardization.
- Microsoft. (2021). *The STRIDE Threat Model*. Microsoft Security Documentation.
- The Open Group. (2019). *ArchiMate® 3.1 Specification*. The Open Group.
- Object Management Group. (2013). *Business Process Model and Notation (BPMN) Version 2.0.2*. OMG.
- Simon, S. (2018). *The C4 Model for Software Architecture*. c4model.com.

Documento preparado con base en el diagnóstico AS-IS del proceso CF-JUR-PRO-002 y los lineamientos metodológicos del marco TOGAF ADM, aplicando análisis crítico de riesgo multidimensional bajo perspectiva de Arquitectura Empresarial para el sector financiero colombiano.